

FACULTY OF INFORMATION AND COMMUNICATION TECHNOLOGY

ITDS 294
Fundamentals of Electronic Commerce Systems

Session 6 : E-Commerce Security and Payment Systems



Session 6

E-Commerce Security and Payment Systems

มุมมองของ E-Commerce Security ตัวอย่างของ Security Threats ในสภาพแวดล้อมของ E-Commerce การทำ E-Commerce Security Plan และรูปแบบการชำระเงินในระบบ E-Commerce

Case Study : Alipay and WeChat Pay Lead in Mobile Payment

เรียนรู้ภาพรวมและแนวทางในการพัฒนาของ Mobile Payment ในประเทศจีน

Learning Outcome for Session 6

E-Commerce Security

นิสิตสามารถระบุ Security Threats ที่อาจจะเกิดขึ้น และสามารถวางแผนการรักษาความปลอดภัยของระบบ E-Commerce

E-Commerce Payment Systems

นิสิตสามารถเลือกรูปแบบการชำระเงินบนระบบ E-Commerce ได้เหมาะสมกับสถานการณ์ที่ต้องการ

Case Study : Alipay and WeChat Pay Lead in Mobile Payment

นิสิตสามารถระบุสาเหตุของการเจริญเติบโตของการใช้ Mobile Payment ในประเทศจีน



E-Commerce Security and Payment Systems

มุมมองของ E-Commerce Security ตัวอย่างของ Security Threats ในสภาพแวดล้อมของ E-Commerce การทำ E-Commerce Security Plan และรูปแบบการชำระเงินในระบบ E-Commerce

E-Commerce Security Environment

For most law-abiding citizens, the Internet holds the promise of a huge and convenient global marketplace, providing access to people, goods, services, and businesses world wide, all at a bargain price. For criminals, the Internet has created entirely new—and lucrative—ways to steal from the more than 2.3 billion online consumers worldwide in 2020.



Scope of The Problem

- Cybercrime is becoming a more significant problem for both organizations and consumers.
- Bot networks, DDoS attacks, Trojans, phishing, ransomware, data theft, identity fraud, credit card fraud, and spyware are just some of the threats that are making daily headlines.
- Social networks also have had security breaches. A security breach is any incident that results in unauthorized access to computer data, applications, networks or devices.

The Value Stolen Information

Criminals who steal information on the Internet do not always use this information themselves, but instead derive value by selling the information to others on the so-called underground or shadow economy market, also sometimes referred to as the Dark Web or the Darknet. Data is currency to cybercriminals and has a "street value" that can be monetized.

TABLE 5.2 THE CYBER MARKET FOR STOLEN DATA

DATA	PRICE*
Individual U.S. card number with expiration date and CVV2 (the three-digit number printed on back of card) (referred to as a CVV)	$5–$8
Individual U.S. card number with full information, including full name, billing address, expiration date, CVV2, date of birth, mother's maiden name, etc. (referred to as a Fullz or Fullzinfo)	$20–$60
Dump data for U.S. card (the term "dump" refers to raw data such as name, account number, expiration data, and CVV encoded on the magnetic strip on the back of the card)	$60–$100
Bank account login credentials (depending on value and verification)	0.5%–10% of value
Online payment accounts (PayPal, etc.) (depending on value and verification)	0.5%–10% of value
Driver's license information	$20
Online account login credentials (Facebook, Twitter, eBay, Apple, Dropbox)	$10–$15
Medical information/health credentials	$10–$20
1,000 e-mail addresses	$1–$10
Scan of a passport	$1–$25
Social security number	$1

Dimensions of E-Commerce Security

There are six key dimensions to e-commerce security: integrity, nonrepudiation, authenticity, confidentiality, privacy, and availability.

Dimensions of E-Commerce Security

Integrity

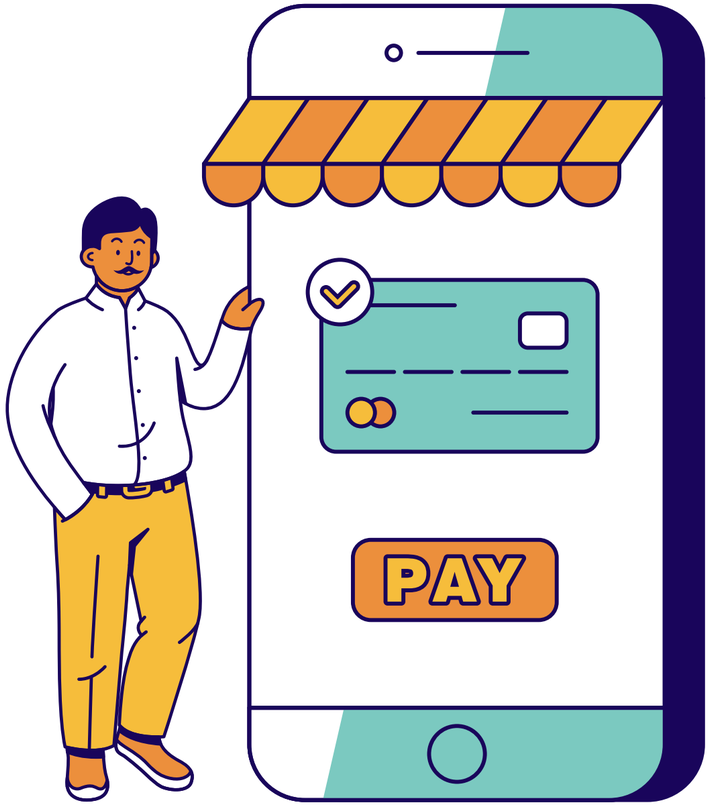
- It refers to the ability to ensure that information being displayed on a web- site, or transmitted or received over the Internet, has not been altered in any way by an unauthorized party.
- For example, if an unauthorized person intercepts and changes the contents of an online communication, such as by redirecting a bank wire transfer into a different account, the integrity of the message has been compromised because the communication no longer represents what the original sender intended.



Dimensions of E-Commerce Security

Nonrepudiation

- It refers to the ability to ensure that e-commerce participants do not deny (i.e., repudiate) their online actions.
- For instance, the availability of free e-mail accounts with alias names makes it easy for a person to post comments or send a message and perhaps later deny doing so.
- Even when a customer uses a real name and e-mail address, it is easy for that customer to order merchandise online and then later deny doing so.
- In most cases, because merchants typically do not obtain a physical copy of a signature, the credit card issuer will side with the customer because the merchant has no legally valid proof that the customer ordered the merchandise.



Dimensions of E-Commerce Security

Authenticity

- It refers to the ability to identify the identity of a person or entity with whom you are dealing on the Internet.
- How does the customer know that the website operator is who it claims to be?
- How can the merchant be assured that the customer is really who she says she is?
- Someone who claims to be someone he is not is “spoofing” or misrepresenting himself.



Dimensions of E-Commerce Security

Confidentiality and Privacy

- It refers to the ability to ensure that messages and data are available only to those who are authorized to view them.
- Confidentiality is sometimes confused with **privacy**, which refers to the ability to control the use of information a customer provides about himself or herself to an e-commerce merchant.
- E-commerce merchants have two concerns related to privacy. They must establish internal policies that govern their own use of customer information, and they must protect that information from illegitimate or unauthorized use.



Dimensions of E-Commerce Security

Availability

- It refers to the ability to ensure that an e-commerce site continues to function as intended.



Dimensions of E-Commerce Security

TABLE 5.3 CUSTOMER AND MERCHANT PERSPECTIVES ON THE DIFFERENT DIMENSIONS OF E-COMMERCE SECURITY

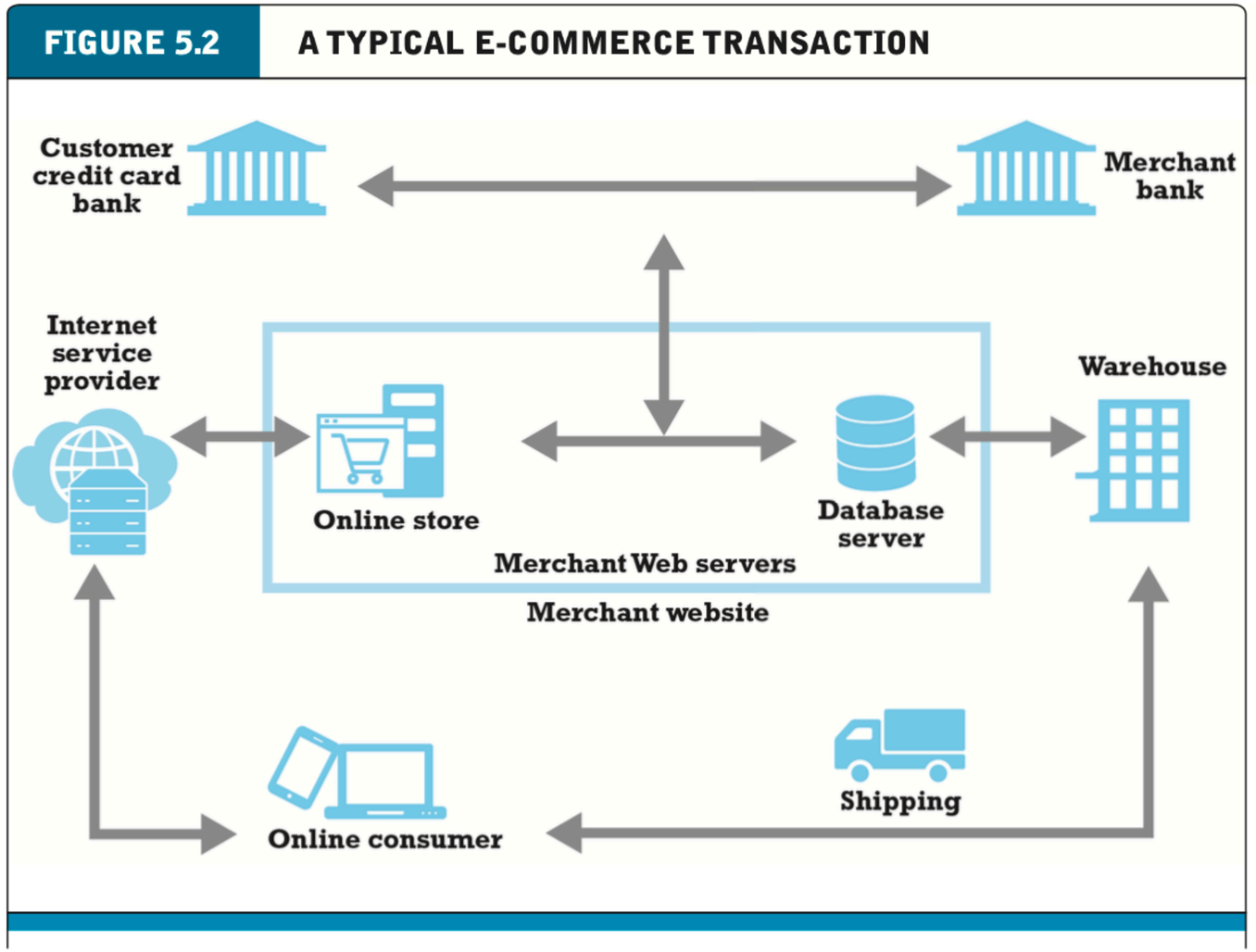
DIMENSION	CUSTOMER'S PERSPECTIVE	MERCHANT'S PERSPECTIVE
Integrity	Has information I transmitted or received been altered?	Has data on the site been altered without authorization? Is data being received from customers valid?
Nonrepudiation	Can a party to an action with me later deny taking the action?	Can a customer deny ordering products?
Authenticity	Who am I dealing with? How can I be assured that the person or entity is who they claim to be?	What is the real identity of the customer?
Confidentiality	Can someone other than the intended recipient read my messages?	Are messages or confidential data accessible to anyone other than those authorized to view them?
Privacy	Can I control the use of information about myself transmitted to an e-commerce merchant?	What use, if any, can be made of personal data collected as part of an e-commerce transaction? Is the personal information of customers being used in an unauthorized manner?
Availability	Can I get access to the site?	Is the site operational?

Security Threats in the E-Commerce Environment

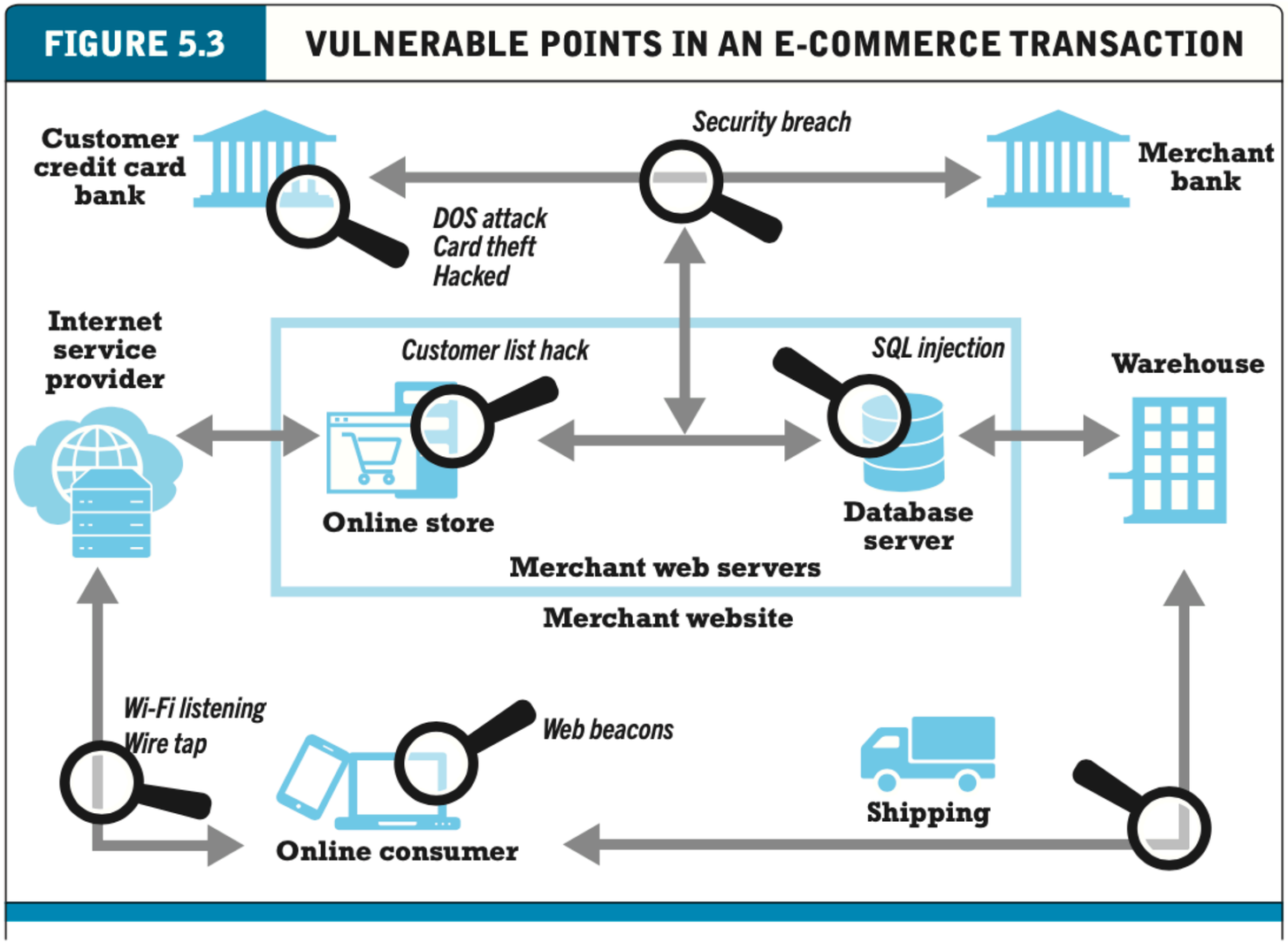
a number of the most common and most damaging forms of security threats to e-commerce consumers and site operators: malicious code, potentially unwanted programs, phishing, hacking and cybervandalism, data breaches, credit card fraud/theft, spoofing, pharming, spam (junk) websites (link farms), identity fraud, Denial of Service (DoS) and DDoS attacks, sniffing, insider attacks, poorly designed server and client software, social network security issues, mobile platform security issues, and finally, cloud security issues.



A Typical E-Commerce Transaction



A Typical E-Commerce Transaction



Malicious Code

Malicious code (sometimes referred to as “malware”) includes a variety of threats such as viruses, worms, ransomware, Trojan horses, and bots. Some malicious code, sometimes referred to as an *exploit*, is designed to take advantage of software vulnerabilities in a computer’s operating system, web browser, applications, or other software components.

Another method for malicious code distribution is to embed it in the online advertising chain (known as **malvertising**), including via Google and other ad networks.

A **drive-by download** is malware that comes with a downloaded file that a user intentionally or unintentionally requests. Drive-by is now one of the most common methods of infecting computers.

A **virus** is a computer program that has the ability to replicate or make copies of itself, and spread to other files.

Malicious Code

Instead of just spreading from file to file, a **worm** is designed to spread from computer to computer. A worm does not necessarily need to be activated by a user or program in order for it to replicate itself.

Ransomware is a type of malware (often a worm) that locks your computer or files to stop you from accessing them and demands that you pay a fine.

A **Trojan horse** appears to be benign, but then does something other than expected.

A **backdoor** is a feature of viruses, worms, and Trojans that allows an attacker to remotely access a compromised computer.

Bots (short for robots) are a type of malicious code that can be covertly installed on your computer when attached to the Internet. Once installed, the bot responds to exter- nal commands sent by the attacker; your computer becomes a “zombie” and is able to be controlled by an external third party (the “bot-herder”)

Potentially Unwanted Programs (PUPs)

The e-commerce security environment is further challenged by **potentially unwanted programs** (**PUPs**), also sometimes referred to as potentially unwanted applications (PUAs), such as adware, browser parasites, spyware, and other applications, including rogue security software, toolbars, and PC diagnostic tools, that install themselves on a computer, typically without the user's informed consent.

Adware is typically used to call for pop-up ads to display when the user visits certain sites. It is increasingly being used as a tool by cybercriminals.

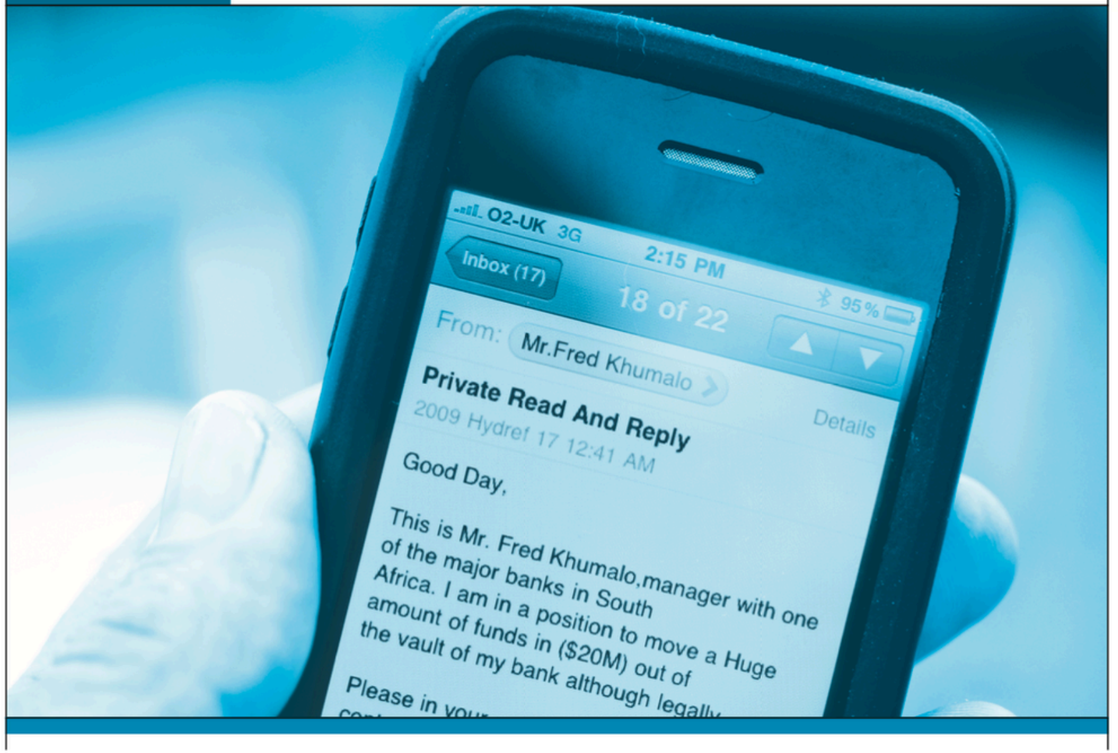
A **browser parasite** (also sometimes referred to as a browser-setting hijacker) is a program that can monitor and change the settings of a user's browser, for instance, changing the browser's home page, or sending information about the sites visited to a remote computer.

Spyware can be used to obtain information such as a user's keystrokes, copies of e-mail and instant messages, and even take screenshots (and thereby capture passwords or other confidential data).

Phishing

Phishing is any deceptive, online attempt by a third party to obtain confidential information for financial gain. Phishing attacks typically do not involve malicious code but instead rely on straightforward misrepresentation and fraud, so-called “social engineering” techniques.

FIGURE 5.4 AN EXAMPLE OF A “NIGERIAN LETTER” E-MAIL SCAM



Data Breaches

A **data breach** occurs whenever organizations lose control over corporate information, including the personal information of customers and employees, to outsiders.

Credential stuffing is a brute force attack which hackers launch via botnets and automated tools using known user name and password combinations (referred to as combo lists) obtained from data breaches.

Credit Card Fraud/Theft

Theft of credit card data is one of the most feared occurrences on the Internet. Fear that credit card information will be stolen prevents users from making online purchases in many cases. Online merchants use a variety of techniques to combat credit card fraud, including using automated fraud detection tools, manually reviewing orders, rejection of suspect orders, and requiring additional levels of security such as e-mail address, zip code, and CVV security codes.

Identity Fraud

Identity fraud involves the unauthorized use of another person's personal data, such as social security, driver's license, and/or credit card numbers, as well as user names and passwords, for illegal financial benefit.

DoS and DDos

In a **Denial of Service** (**DoS**) **attack**, hackers flood a website with useless pings or page requests that inundate and overwhelm the site's web servers. Increasingly, DoS attacks involve the use of bot networks and so-called "distributed attacks" built from thousands of compromised client computers. DoS attacks typically cause a website to shut down,

A **Distributed Denial of Service** (**DDoS**) **attack** uses hundreds or even thousands of computers to attack the target network from numerous launch points. DoS and DDoS attacks are threats to a system's operation because they can shut it down indefinitely.

Poorly Designed Software

Many security threats prey on poorly designed software, sometimes in the operating system and sometimes in the application software, including browsers.

SQL injection attacks take advantage of vulnerabilities in poorly coded web application software that fails to properly validate or filter data entered by a user on a web page to introduce malicious program code into a company's systems and networks.

A **zero-day vulnerability** is one that has been previously unreported and for which no patch yet exists.

A flaw in the OpenSSL encryption system, used by millions of websites, known as the **Heartbleed bug**, was discovered . The vulnerability allowed hackers to decrypt an SSL session and discover user names, passwords, and other user data, by using OpenSSL in combination with a communications protocol called the RFC6520 heartbeat that helps a remote user remain in touch after connecting with a website server.

A Security Plan :
Management Policies

In order to minimize security threats, e-commerce firms must develop a coherent cor- porate policy that takes into account the nature of the risks, the information assets that need protecting, and the procedures and technologies required to address the risk, as well as implementation and auditing mechanisms.



Developing an E-Commerce Security Plan



Developing an E-Commerce Security Plan

A security plan begins with **risk assessment**—an assessment of the risks and points of vulnerability. The first step is to inventory the information and knowledge assets of the e-commerce site and company. What information is at risk? Is it customer information, proprietary designs, business activities, secret processes, or other internal information, such as price schedules, executive compensation, or payroll? For each type of information asset, try to estimate the dollar value to the firm if this information were compromised, and then multiply that amount by the probability of the loss occurring. Once you have done so, rank order the results. You now have a list of information assets prioritized by their value to the firm.

Developing an E-Commerce Security Plan

Based on your quantified list of risks, you can start to develop **a security policy**—a set of statements prioritizing the information risks, identifying acceptable risk targets, and identifying the mechanisms for achieving these targets.

Next, consider an **implementation plan**—the steps you will take to achieve the security plan goals. Specifically, you must determine how you will translate the levels of acceptable risk into a set of tools, technologies, policies, and procedures. What new technologies will you deploy to achieve the goals, and what new employee procedures will be needed?

To implement your plan, you will need an organizational unit in charge of security, and a security officer—someone who is in charge of security on a daily basis. For a small e-commerce site, the security officer will likely be the person in charge of Internet ser- vices or the site manager, whereas for larger firms, there typically is a dedicated team with a supporting budget. The **security organization** educates and trains users, keeps management aware of security threats and breakdowns, and maintains the tools chosen to implement security.

Developing an E-Commerce Security Plan

The last step in developing an e-commerce security plan is performing a **security audit**. A security audit involves the routine review of access logs (identifying how outsid- ers are using the site as well as how insiders are accessing the site's assets). A monthly report should be produced that establishes the routine and nonroutine accesses to the systems and identifies unusual patterns of activities.

E-Commerce Payment Systems

For the most part, existing payment mechanisms such as cash, credit cards, debit cards, checking accounts, and stored value accounts have been able to be adapted to the online environment, albeit with some significant limitations that have led to efforts to develop alternatives. In addition, new types of purchasing relationships, such as between individuals online, and new technologies, such as the development of the mobile platform, have also created both a need and an opportunity for the development of new payment systems.



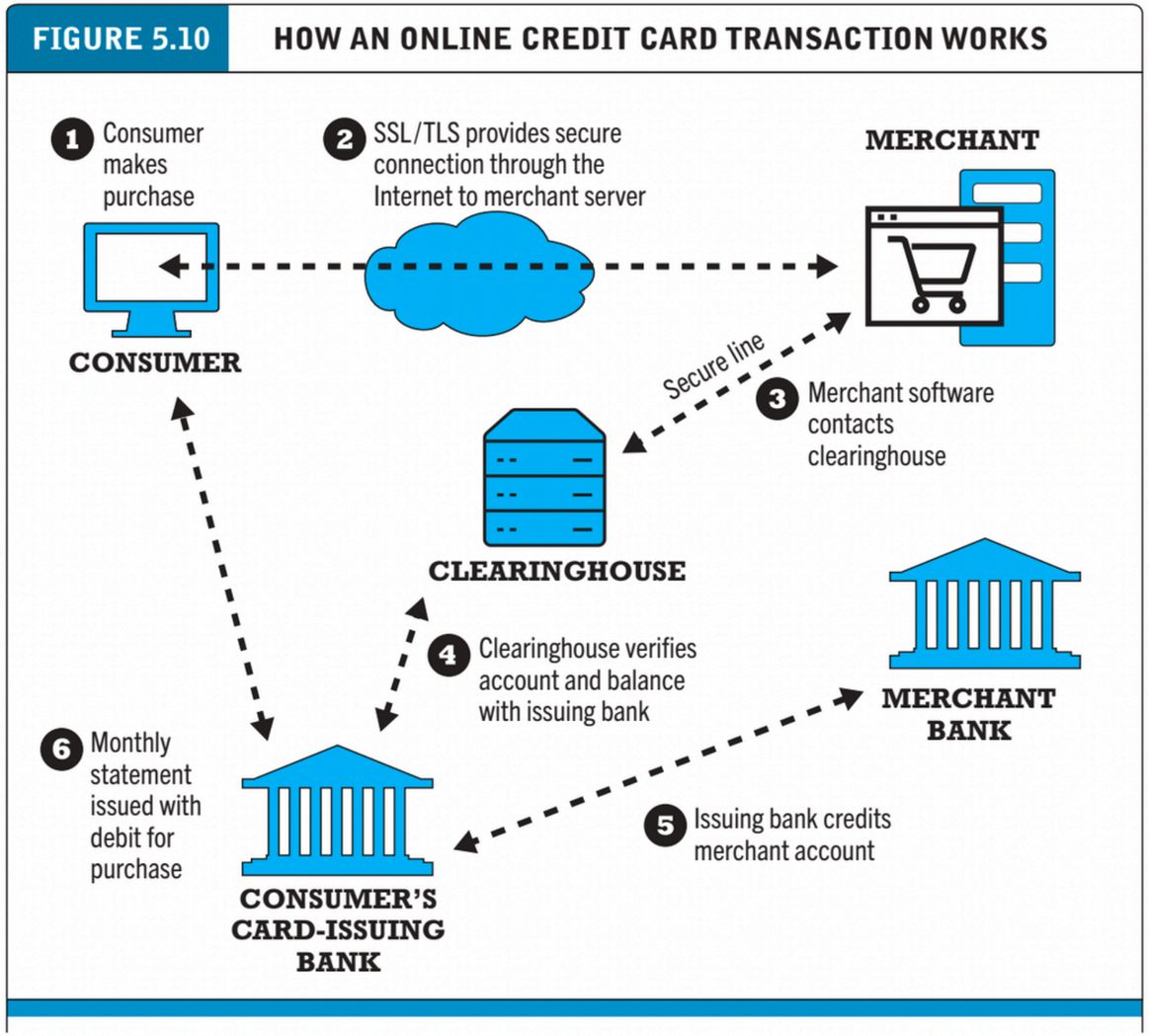
E-Commerce Payment Systems

TABLE 5.6 MAJOR TRENDS IN E-COMMERCE PAYMENTS 2022–2023

- Payment by credit and/or debit card remains the dominant form of online payment.
- Online payment volume surges because of the Covid-19 pandemic.
- Mobile retail adoption and payment volume skyrockets.
- PayPal remains the most popular alternative payment method online.
- Apple, Google, and Samsung extend their reach in mobile payment apps; Google Pay and Samsung Pay rebrand as Google Wallet and Samsung Wallet in most countries to emphasize functionalities they provide beyond mobile payment.
- Growing convergence in the online payments marketplace: Large banks enter the mobile wallet and P2P payments market with apps such as Zelle, while Apple introduces a credit card.
- Mobile P2P payment systems such as Venmo, Zelle, and Square Cash take off. Most mobile wallets also offer P2P payments.
- Buy Now Pay Later (BNPL) payment services increase in popularity.
- Interest in cryptocurrencies such as Bitcoin surges, even as prices crash and concerns about security increase.

E-Commerce Payment Systems

Because credit and debit cards are the dominant form of online payment, it is important to understand how they work and to recognize the strengths and weaknesses of this payment system.



E-Commerce Payment Systems

Today, Internet payment service providers (sometimes referred to as payment gateways) can provide both a merchant account and the software tools needed to process credit card purchases online.

For instance, **Authorize.net** is an online payment service provider. The company helps a merchant secure an account with one of its merchant account provider partners and then provides payment processing software for installation on the merchant's server. The software collects the transaction information from the merchant's site and then routes it via the Authorize.net "payment gateway" to the appropriate bank, ensuring that customers are authorized to make their purchases. The funds for the transaction are then transferred to the merchant's merchant account. Other online payment service providers include Cybersource, Stripe, and Square.

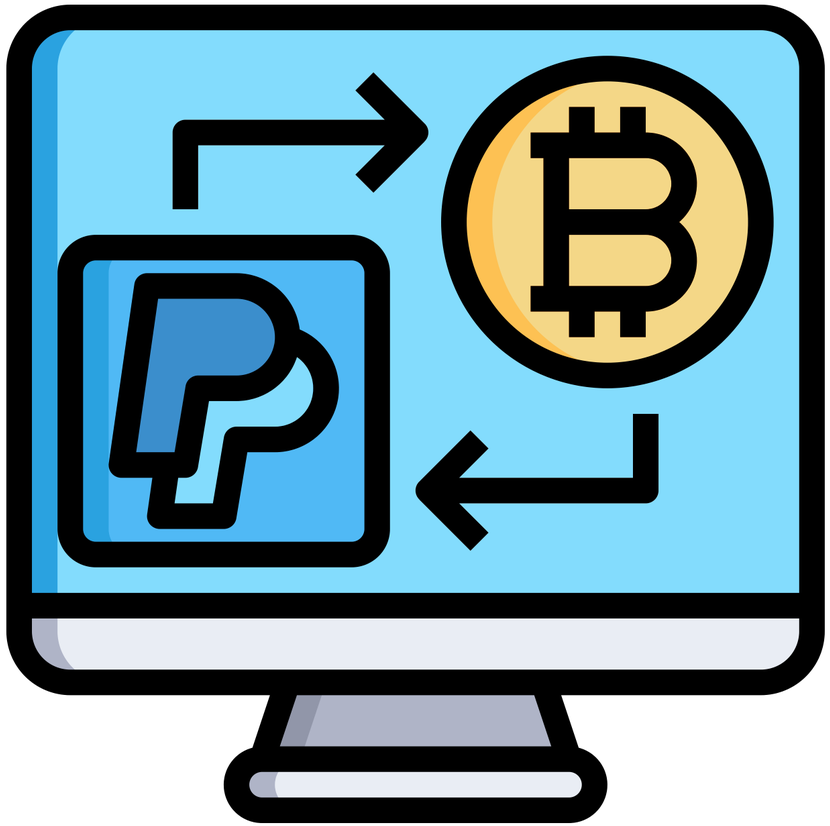
E-Commerce Payment Systems

The **PCI-DSS** (**Payment Card Industry-Data Security Standard**) is a global data security standard instituted by the five major credit card companies (Visa, MasterCard, American Express, Discover, and JCB). PCI-DSS is not a law or governmental regulation, but an industry-mandated standard. Every online merchant must comply with the appropriate level of PCI-DSS in order to accept credit card payments.

Alternative Online Payment Systems

Online Stored Value Payment System

Paypal enables individuals and businesses with e-mail accounts to make and receive payments up to a specified limit. Paypal is an example of an **online stored value payment system**, which permits consumers to make online payments to merchants and other individuals using their bank account or credit/debit cards.



Alternative Online Payment Systems

Mobile Payment System : Smartphone Wallet

Mobile payment systems are the fastest growing component of alternative payments. The use of mobile devices as payment mechanisms is already well established in Asia and many countries in Europe, such as Denmark, Norway, Italy, and the Netherlands, and is now growing in the United States, where the infrastructure to support mobile payment is now in place.

Mobile wallets (sometimes also referred to as digital wallets) are smartphone apps that store debit cards, reward coupons, invoices, and vouchers that might be found in a traditional wallet



Alternative Online Payment Systems

Mobile Payment System : Smartphone Wallet

There are three primary types of mobile wallet apps: universal proximity wallets, branded store proximity wallets, and P2P apps. **Universal proximity mobile wallets**, such as Apple Pay, Google Pay, and Samsung Pay, that can be used at a variety of merchants for point-of-sale transactions if the merchant supports that service (e.g., has an Apple merchant app and can accept such payments), are the most-well known and common type. **Branded store proximity mobile wallets** are mobile apps that can be used only at a single merchant. For instance, Walmart, Tesco, and Starbucks all have very successful mobile wallet apps. **P2P mobile payment apps**, such as Venmo and Square Cash, are used for payments among individuals who have the same app.



Alternative Online Payment Systems

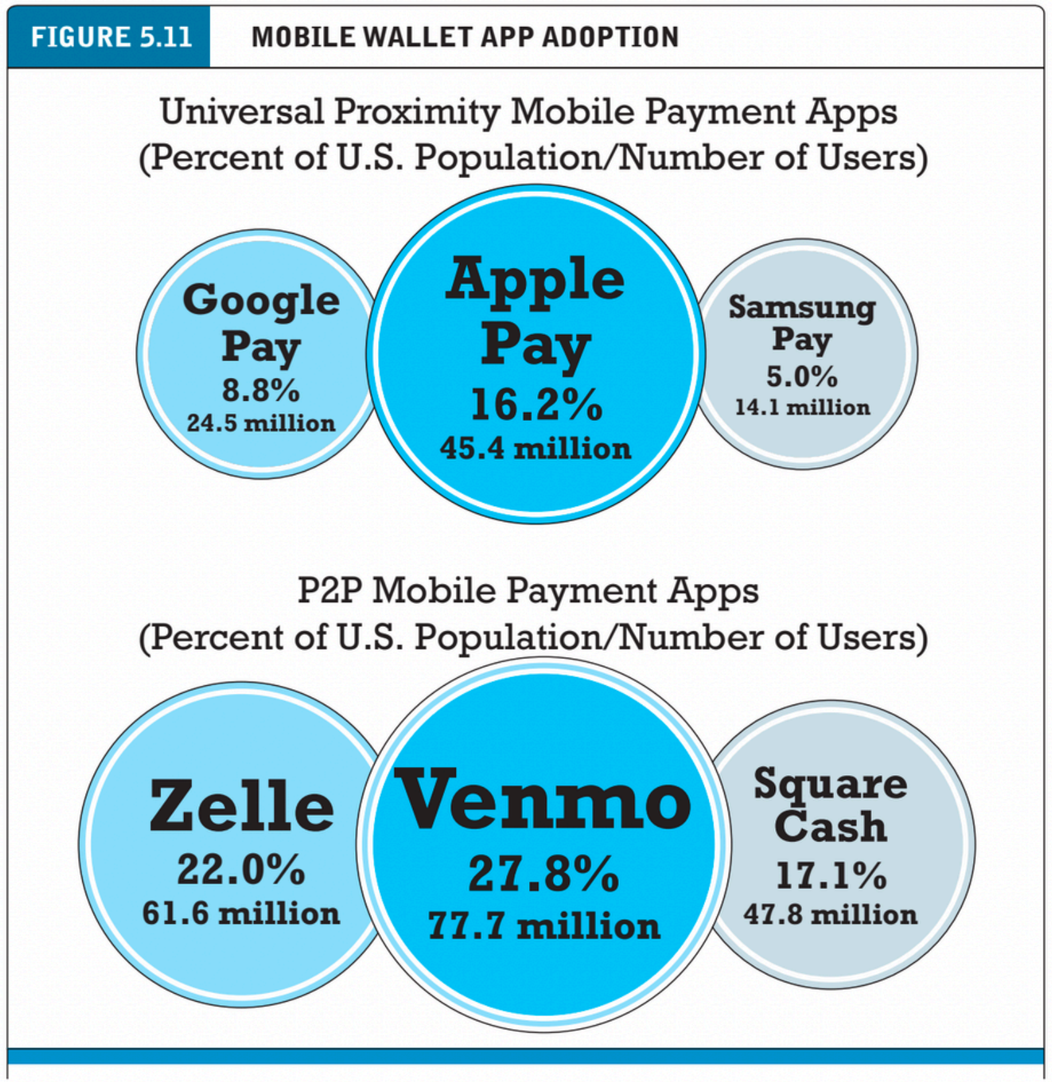
Mobile Payment System : Smartphone Wallet

Near field communication (**NFC**) is the primary enabling technology for universal proximity mobile wallets, while QR code technology is typically used for branded store proximity mobile wallets.

Quick Response (**QR**) **code technology** uses a mobile app to generate a two-dimensional bar code (the QR code) in which information is encoded. The merchant then scans the QR code and the payment amount is deducted from the customer's mobile wallet, which is linked to a credit card or debit card.



Alternative Online Payment Systems

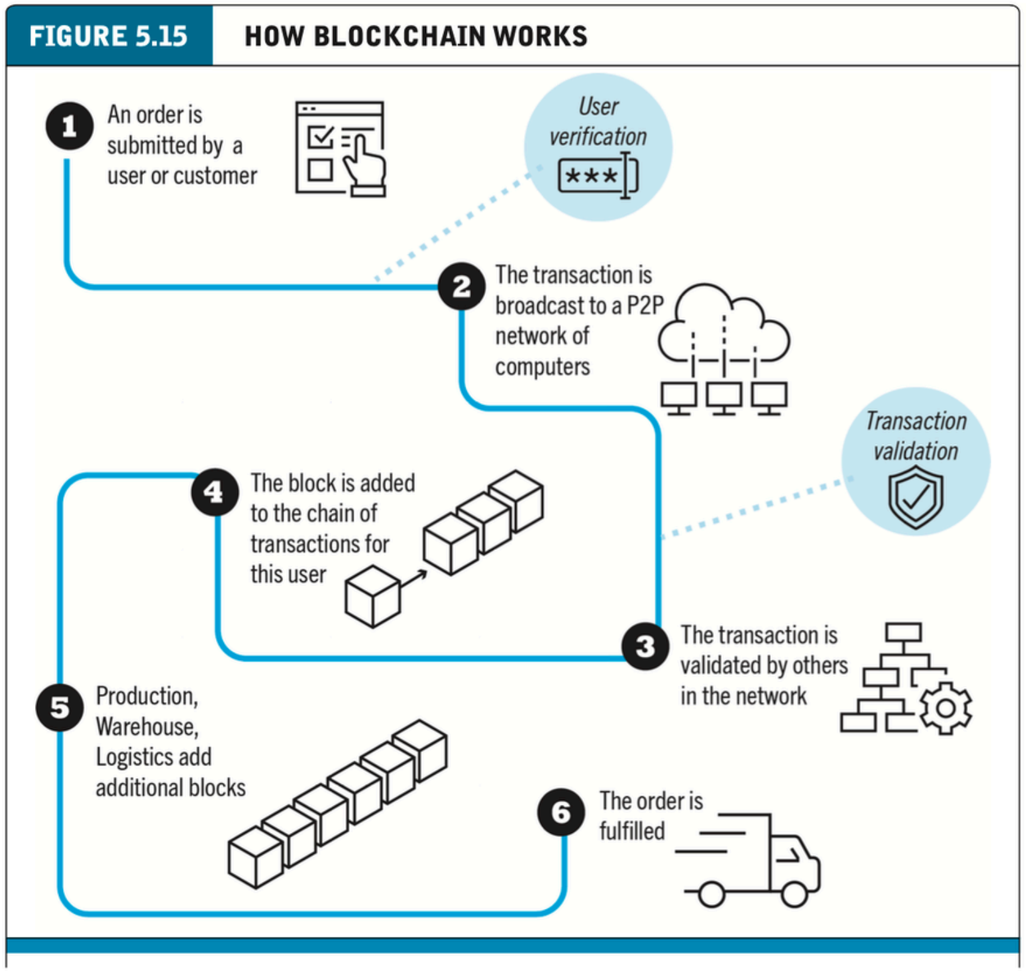


Alternative Online Payment Systems

Blockchain and Cryptocurrencies

Blockchain is a technology that enables organizations to create and verify transactions on a network nearly instantaneously without a central authority. A **blockchain system** is a transaction processing system that operates on a distributed and shared database (called a peer-to-peer or P2P computer network) rather than a single organization's database.

Cryptocurrencies are purely digital assets that work as a medium of exchange using blockchain technology and cryptography. **Bitcoin** is the most prominent example of cryptocurrency in use today, but many other cryptocurrencies have emerged in the last few years



Alternative Online Payment Systems

TABLE 5.10 EXAMPLES OF ALTCOINS

NAME	DESCRIPTION
Ethereum/Ether	Ethereum is a decentralized software platform that allows blockchain-based apps to be built and used using Ether, the platform's currency. Lower transaction costs and faster transaction speeds than Bitcoin.
Ripple	A real-time global settlement network that allows for instant low-cost international payments. The distributed ledger of Ripple does not require coin mining to update, making Ripple unique among altcoins. Backed by major banking organizations.
Bitcoin Cash	Result of a fork in Bitcoin's currency—larger block sizes, faster transaction speeds, and lower transaction fees.
Litecoin	Lightweight coin that generates blocks and confirms transactions faster than Bitcoin.
Monero	Coin with special focus on privacy, using different hash algorithms and other techniques to anonymize all elements of a transaction.
Zcash	Coin with "shielded" transactions that hide even the amount transacted.



Case Study : Alipay and WeChat Pay Lead in Mobile Payments

เรียนรู้ภาพรวมและแนวทางในการพัฒนาของ Mobile Payment ในประเทศจีน

Do you have any questions?

มีคำถามหรือข้อสงสัยเกี่ยวกับเนื้อหาที่เรียนในวันนี้





Next Session Topic

หัวข้อสำหรับสัปดาห์หน้า

- E-Commerce Marketing and Advertising